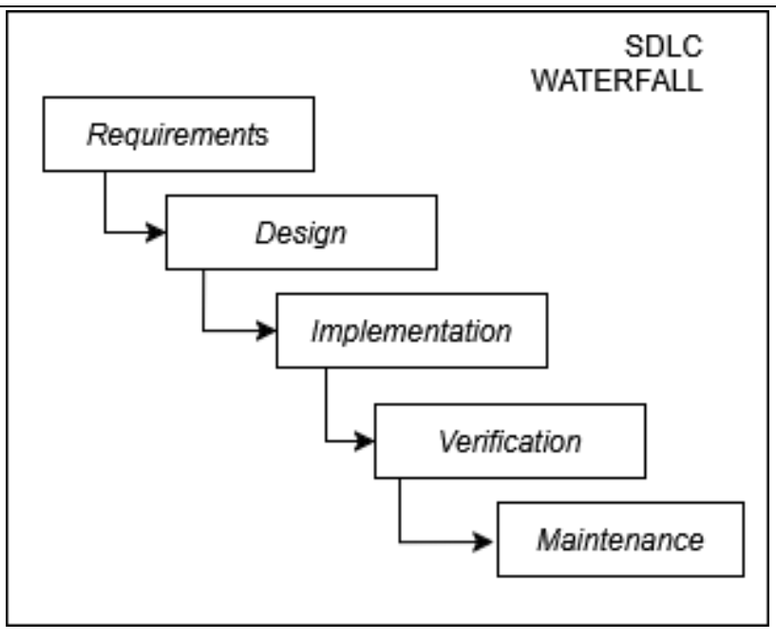
(1) Identitas Mahasiswa	
Nama	Martua Raja Doli Pangaribuan
NPM	2221101809
Program Studi	Rekayasa Keamanan Siber
Bidang Minat	-
(2) Topik Penelitian	Pengembangan Agentic AI dengan Sistem Multi-Agen Berbasis LLM untuk Otomasi Pengujian Keamanan Web Berdasarkan Standar OWASP WSTG 4.2 menggunakan Model Context Protocol
(3) Latar Belakang Penelitian	Keamanan sistem digital masih menjadi tantangan utama di tengah keterhubungan layanan publik dan bisnis. Berdasarkan Lanskap Keamanan Siber Indonesia 2024 yang dirilis oleh Badan Siber dan Sandi Negara Republik Indonesia (BSSN), melaporkan temuan celah keamanan pada aplikasi web, mobile, serta infrastruktur yang dimiliki oleh instansi pemerintah pusat, pemerintah daerah, dan sektor Infrastruktur Informasi Vital (IIV). Dari jumlah tersebut, 256 celah tergolong *Critical*, 405 termasuk dalam kategori *High*, dan 350 diklasifikasikan sebagai *Medium* berdasarkan tingkat risikonya. Hal ini menunjukkan aplikasi web tetap menjadi permukaan serangan yang perlu diprioritaskan (BSSN, 2025). Di level global, laporan tahunan HackerOne 2024 mencatat sebanyak 78.042 laporan kerentanan yang valid, meningkat 12% dibanding tahun sebelumnya. Dari jumlah tersebut, 88% menargetkan aplikasi web, menjadikannya aset paling rentan dibandingkan aset lainnya (Hackerone, 2024). Tingginya angka kerentanan ini berdampak langsung pada operasional bisnis seperti kerugian finansial akibat kerusakan sistem dan kehilangan kepercayaan dari pelanggan yang mendorong peningkatan pengujian keamanan, namun terkendala biaya tinggi dan keterbatasan sumber daya ahli. Di saat kebutuhan otomasi pertahanan meningkat, laporan State of Cybersecurity 2024 dari ISACA menyoroti bahwa penggunaan A*rtificial Intelligence* (AI) dalam operasi keamanan siber masih sangat terbatas. Hanya 28% organisasi yang menggunakan AI untuk otomatisasi deteksi ancaman, 27% untuk keamanan *endpoint* dan 24% untuk otomasi tugas rutin. Selain itu, sebagian profesional keamanan siber belum terlibat dalam pengembangan atau

	implementasi AI. (ISACA, 2024). Rendahnya adopsi AI dalam keamanan siber ini membuka peluang untuk mengembangkan solusi yang dapat menjembatani kesenjangan antara kebutuhan pengujian keamanan yang komprehensif dengan keterbatasan sumber daya manusia yakni dengan otomatisasi. Salah satu pendekatan yang banyak digunakan untuk mengidentifikasi celah keamanan secara proaktif adalah Uji Penetrasi (*penetration testing)*, yaitu *metode offensive security* yang bertujuan untuk mensimulasikan serangan nyata terhadap suatu sistem. Uji penetrasi umumnya terdiri dari lima fase: pengintaian, pemindaian, penilaian kerentanan, eksploitasi, dan pelaporan (Božić et al., 2019). Praktik terkini banyak memanfaatkan alat otomatis seperti SQLmap, Dalfox, dan OWASP ZAP, namun penggunaannya masih tersebar dalam bentuk antarmuka baris perintah (*command line interface*) dengan sintaks beragam, sehingga memerlukan pemahaman teknis lebih agar maksimal yang tentunya menyulitkan pengguna non-teknis. (Abdulghaffar et al., 2023)(Singh et al., 2021). Seiring berkembangnya teknologi, integrasi LLM dalam uji penetrasi menjadi topik yang kian dieksplorasi. Penelitian terbaru mengevaluasi pemanfaatan *prompt engineering*, *fine-tuning*, dan *Retrieval Augmented Generation* (RAG) untuk mengoperasikan serta menginterpretasi keluaran alat keamanan melalui bahasa alami. (Goyal et al., 2024). Pendekatan ini membuka potensi penggunaan LLM sebagai asisten cerdas dalam mengoperasikan dan menginterpretasi hasil alat pengujian keamanan. Di sisi lain, PentestGPT memperkenalkan arsitektur dengan tiga komponen utama yaitu *reasoning*, *generation*, dan *parsing*. Sistem ini mendemonstrasikan peningkatan performa task completion sebesar 228.6% dibandingkan dengan *baseline* GPT-3.5. Meskipun demikian, penelitian tersebut mengidentifikasi beberapa limitasi, termasuk kehilangan konteks (*context loss*) dan kebutuhan akan intervensi manusia dalam menangani skenario pengujian yang kompleks (Deng et al., 2024). Pendekatan berbeda dari HackSynth yang mengimplementasikan arsitektur *dual-module* terdiri dari komponen *Planner* dan *Summarizer* untuk melakukan uji penetrasi otomatis pada tantangan *Capture The Flag* (CTF). Namun demikian, sistem ini memiliki keterbatasan dalam hal eksekusi yang masih bersifat sequential dan belum secara spesifik menargetkan pengujian keamanan aplikasi web (Muzsai et al., 2024). Sementara itu, PENTEST-AI mengimplementasikan arsitektur multiagen dengan pembagian peran spesifik untuk *scanning*, *exploit*, *validation*, dan *reporting,* serta mengintegrasikan basis pengetahuan MITRE ATT&CK untuk memandu proses pengujian. (Bianou & Batogna, 2024). Meskipun sistem ini mendemonstrasikan pendekatan multiagen dengan tahapan yang terstruktur,

	kerangka MITRE ATT&CK yang digunakan bersifat umum dan tidak secara langsung mencerminkan prosedur uji yang dibutuhkan untuk pengujian keamanan aplikasi web. Rangkaian temuan tersebut menegaskan adanya kesenjangan yang perlu dijawab. Meskipun PENTEST-AI telah mengimplementasikan arsitektur multiagen untuk otomasi uji penetrasi, kerangka evaluasi MITRE ATT&CK yang digunakan bersifat umum dan tidak secara spesifik mencerminkan prosedur pengujian keamanan aplikasi web. PentestGPT masih menggunakan pendekatan single-agent yang rentan terhadap kehilangan konteks, sementara HackSynth berfokus pada tantangan CTF dengan eksekusi sequential. Belum ada implementasi yang secara spesifik mengintegrasikan arsitektur multiagen dengan standar OWASP WSTG versi 4.2 melalui protokol Model Context Protocol (MCP) untuk pengujian keamanan apliaksi web secara sistematis. Penelitian ini memfokuskan evaluasi pada pendekatan kecerdasan agenik dengan arsitektur multiagen terspesialiasi untuk penilaian kerentanan aplikasi web. Setiap agen memiliki keahlian yang selaras dengan kategori dalam OWASP Web Security Testing Guide versi 4.2 yakni *Information Gathering*, *Configuration and Deployment Management Testing*, *Identity Management Testing*, *Authentication Testing*, *Authorization Testing*, *Session Management Testing*, *Input Validation Testing*, *Testing for Error Handling*, *Testing for Weak Cryptography*, *Business Logic Testing* dan *Client Side Testing (OWASP Foundation, 2020)*. OWASP WSTG dipilih sebagai kerangka evaluasi karena menyediakan daftar uji yang rinci dan komprehensif dan relevan khusus untuk aplikasi web.(Wake et al., 2023) Untuk menyederhanakan integrasi dengan alat uji, penelitian ini memanfaatkan *Model Context Protocol* (MCP) yang diperkenalkan pada 2024. Protokol ini menempatkan LLM sebagai klien yang berkomunikasi dengan penyedia alat dan sumber data melalui JSON-RPC 2.0 sehingga perintah pemindaian atau eksploitasi dapat disalurkan dengan mekanisme yang konsisten (Anthropic, 2024). Selain itu, OWASP Juice Shop digunakan sebagai *benchmark dataset* karena memiliki tantangan keamanan terstandarisasi yang sesuai dengan kategori OWASP WSTG 4.2 dan telah digunakan dalam penelitian terkini. (Izzat et al., 2025) Berdasarkan latar belakang tersebut, penelitian ini bertujuan untuk mengembangkan sistem multiagen berbasis Large Language Model (LLM) yang mampu mengotomatisasi pengujian keamanan aplikasi web secara menyeluruh berdasarkan standar OWASP Web Security Testing Guide (WSTG) versi 4.2. Penelitian ini juga bertujuan untuk mengevaluasi efektivitas sistem yang dikembangkan dalam mendeteksi kerentanan secara valid, dengan tingkat positif palsu yang rendah, serta efisiensi pelaksanaan pengujian.

	Penilaian dilakukan dengan mempertimbangkan indikator kinerja seperti cakupan pengujian (completion rate), menguji fungsi-fungsi teknis pada sistem, menguji performa sistem dan menguji kelayakan sistem apakah layak atau tidaknya digunakan.
(4) Penelitian Terkait/Referensi	Abdulghaffar, K., Elmrabit, N., & Yousefi, M. (2023). Enhancing Web Application Security through Automated Penetration Testing with Multiple Vulnerability Scanners. *Computers 2023, Vol. 12, Page 235*, *12*(11), 235. https://doi.org/10.3390/COMPUTERS12110235 Aliyah Aliyah, Nahrun Hartono, & Asrul Azhari Muin. (2024). Penggunaan User Acceptance Testing (UAT) Pada Pengujian Sistem Informasi Pengelolaan Keuangan Dan Inventaris Barang. *Switch : Jurnal Sains Dan Teknologi Informasi*, *3*(1), 84–100. https://doi.org/10.62951/switch.v3i1.330 Anthropic. (2024, November 25). *Introducing the Model Context Protocol*. Https://Www.Anthropic.Com/News/Model-Context-Protocol. https://www.anthropic.com/news/model-context-protocol Bianou, S. G., & Batogna, R. G. (2024). PENTEST-AI, an LLM-Powered Multi-Agents Framework for Penetration Testing Automation Leveraging Mitre Attack. *Proceedings of the 2024 IEEE International Conference on Cyber Security and Resilience, CSR 2024*, 763–770. https://doi.org/10.1109/CSR61664.2024.10679480 Božić, K., Penevski, N., & Adamović, S. (2019). Penetration Testing and Vulnerability Assessment: Introduction, Phases, Tools and Methods. *Sinteza 2019 - International Scientific Conference on Information Technology and Data Related Research*, 229–234. https://doi.org/10.15308/SINTEZA-2019-229-234 BSSN. (2025). *Lanskap Keamanan Siber Indonesia 2024*. Deng, G., Liu, Y., Mayoral-Vilches, V., Liu, P., Li, Y., Xu, Y., Zhang, T., Liu, Y., Pinzger, M., & Rass, S. (2024). *PentestGPT: An LLM-empowered Automatic Penetration Testing Tool*. http://arxiv.org/abs/2308.06782 Fariyono, F., & Sanjaya, W. (2023). Penerapan Metode System Usability Scale untuk Analisis UI/UX Website UMKM Lancar Jaya Food. *JITU : Journal Informatic Technology And Communication*, *7*(1), 59–71. https://doi.org/10.36596/jitu.v7i1.1020 Goyal, D., Subramanian, S., Peela, A., & Shetty, N. P. (2024). *Hacking, The Lazy Way: LLM Augmented Pentesting*. Hackerone. (2024). *8th Annual Hacker-Powered Security Report 2024-2025*. ISACA. (2024). *State of Cybersecurity 2024*. Izzat, M., Saputra, F. A., & Syarif, I. (2025). Design and Implementation of Distributed Web Application Vulnerability Assessment Tools for Securing Complex Microservices Environment. *International*

	Journal of Safety and Security Engineering, *15*(2), 267–273. https://doi.org/10.18280/ijsse.150207 Muzsai, L., Imolai, D., & Lukács, A. (2024). *HackSynth: LLM Agent and Evaluation Framework for Autonomous Penetration Testing*. http://arxiv.org/abs/2412.01778 OWASP Foundation. (2020, December 3). *OWASP WSTG - v4.2*. https://owasp.org/www-project-web-security-testing-guide/v42/ *OWASP Juice Shop	OWASP Foundation*. (n.d.). Retrieved December 3, 2025, from https://owasp.org/www-project-juice-shop/ Singh, A. S. B., Yusof, Y., & Nathan, Y. (2021). EAGLE: GUI-Based Penetration Testing Tool for Scanning and Enumeration. *Proceedings - International Conference on Developments in ESystems Engineering, DeSE*, *2021-Decem*, 97–101. https://doi.org/10.1109/DESE54285.2021.9719338 *Software and systems engineering-Software testing-Part 1: General concepts Foreword*. (2022). www.iso.org Wake, P., Black, S., & Young, J. (2023). Work in Progress: Evaluation of Security Standards through a Cyber Range using Hackers' Tactics, Techniques and Procedures. *Proceedings - 8th IEEE European Symposium on Security and Privacy Workshops, Euro S and PW 2023*, 653–658. https://doi.org/10.1109/EuroSPW59978.2023.00076
(5) Rumusan Masalah	1. Bagaimana tingkat validitas hasil deteksi kerentanan yang dihasilkan oleh sistem multiagen berbasis LLM saat diuji menggunakan OWASP Juice Shop, berdasarkan standar OWASP WSTG v4.2, dan diukur menggunakan metrik Precision, Recall, serta F1-Score (F-Measure) sebagaimana digunakan dalam penelitian Izzat et al. (2025)? 2. Bagaimana kinerja sistem multiagen berbasis LLM dalam menyelesaikan challenge OWASP Juice Shop, ditinjau dari indikator Task Completion Rate (TCR), False Positive Rate (FPR), Average Time per Test (ATT), dan System Usability Scale (SUS) dibandingkan baseline manual
(6) Isi Pokok Bahasan	1. Analisis Masalah dan Studi Literatur dalam Pengujian Keamanan Aplikasi Web 2. Tahapan Penelitian Berdasarkan Metode SDLC (Software Development Life Cycle) Penelitian ini mengadaptasi model SDLC berbasis pendekatan Waterfall sebagai kerangka kerja dalam membangun sistem multiagen untuk pengujian keamanan website.



Tahapan yang digunakan meliputi:

a. *Requirements*

Tahap awal penelitian ini dimulai dengan identifikasi kebutuhan sistem secara menyeluruh, baik kebutuhan fungsional maupun non-fungsional. Kebutuhan fungsional meliputi kemampuan sistem untuk menjalankan pengujian keamanan aplikasi web berdasarkan standar OWASP WSTG v4.2, sementara kebutuhan non-fungsional mencakup aspek efisiensi, modularitas, serta integrasi dengan alat uji eksternal. Selain itu, pada tahap ini juga ditentukan protokol komunikasi yang digunakan agen untuk berkomunikasi dengan alat uji eksternal, yaitu Model Context Protocol (MCP), serta pembentukan spesifikasi struktur perintah yang diteruskan ke agen melalui format JSON-RPC 2.0.

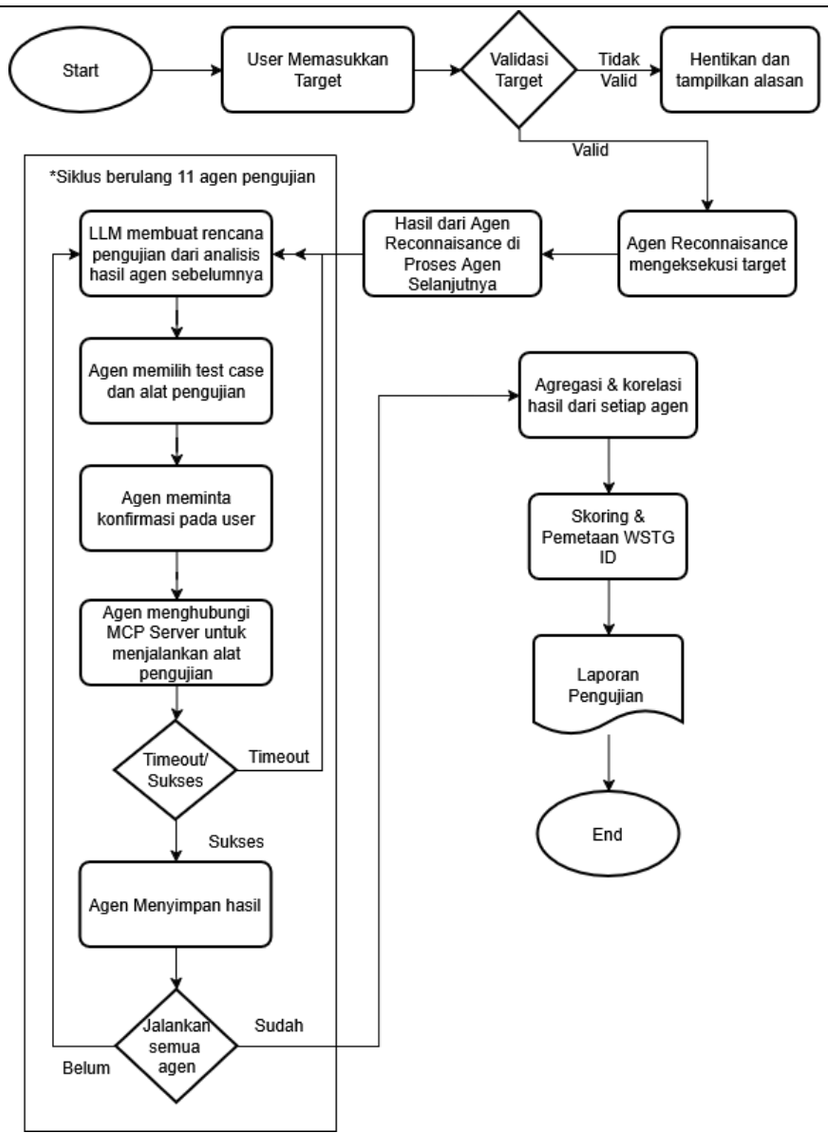
b. *Design*

Tahap desain dilakukan untuk merancang arsitektur sistem multiagen yang terdiri dari sebelas agen spesialis, masing-masing menangani satu atau lebih kategori uji dari OWASP WSTG. Desain ini tidak hanya mencakup pemetaan tanggung jawab agen, tetapi juga penyusunan diagram alur kerja dan skenario pengujian yang memungkinkan integrasi antaragen secara efisien.

c. *Implementation*

Proses implementasi mencakup pembangunan agen-agen berbasis LLM yang terhubung ke alat pengujian seperti subfinder, Dalfox, dan SQLmap. Setiap agen dirancang agar dapat menerima perintah secara independen namun tetap dalam koordinasi protokol MCP. Implementasi dilakukan secara modular agar memungkinkan pengembangan dan pengujian bertahap pada setiap komponen sistem. Sistem ini dikembangkan dalam lingkungan virtualisasi menggunakan docker agar fleksibel saat melakukan

	simulasi terhadap berbagai skenario pengujian keamanan. d. *Verification* Tahapan verifikasi dilakukan melalui serangkaian uji fungsional terhadap sistem yang telah dikembangkan. Pengujian dilakukan pada aplikasi web rentan OWASP Juice Shop yang memiliki challenge terstandarisasi sebagai *ground truth* evaluasi (*OWASP Juice Shop | OWASP Foundation*, n.d.). Tujuan utama dari tahap ini adalah untuk mengukur akurasi sistem dalam mendeteksi kerentanan, sejauh mana cakupan pengujian OWASP berhasil dijalankan, dan seberapa efisien sistem mengeksekusi tugasnya. Selain itu, dilakukan pula perbandingan hasil antara sistem multiagen ini dengan alat pengujian otomatis lain serta agen AI seperti PentestGPT, dengan indikator pengukuran berupa tingkat false positive, kecepatan proses, dan kualitas penjelasan terhadap temuan keamanan. e. *Maintenance* Setelah proses verifikasi selesai, dilakukan pemeliharaan sistem berdasarkan hasil evaluasi sebelumnya. Perbaikan dilakukan terhadap modul yang menghasilkan keluaran tidak akurat, atau terhadap jalur komunikasi antar agen yang belum optimal. Sistem akhir kemudian disusun dalam bentuk antarmuka interaktif dan dilengkapi dengan dasbor visualisasi hasil uji. Validasi tambahan dilakukan oleh evaluator independen untuk memastikan bahwa sistem memenuhi standar fungsionalitas dan keandalan dalam konteks pengujian keamanan aplikasi web. 3. Perancangan Arsitektur Agen Autonomous Multi agent System dengan Protokol MCP untuk Pengujian Website.



a. Pengguna memasukkan perintah pengujian berupa URL atau IP ke dalam LLM melalui antarmuka website.
b. Agen Reconaissance memproses perintah tersebut lalu menjalankan alat pengujian terkait untuk melakukan tahap Reconaissance.
c. Setelah terdapat hasil dari *tools* Reconaissance, hasilnya akan dikirimkan ke agen-agen selanjutnya lalu membuat perencanaan bagaimana langkah serangan beserta *tools* apa saja yang akan digunakan selanjutnya (Terdapat 11 agen yang sesuai dengan tahap pengujian pada standar OWASP WSTG 4.2).
d. Setelah menyusun perencanaan, agen meminta konfirmasi pada user untuk mengeksekusi alat pengujian menggunakan MCP Server.
e. Agen menginisiasi koneksi ke Server MCP untuk mengakses alat pengujian yang sesuai dengan perencanaan yang dibuat pada proses sebelumnya.
f. Kemudian setelah mendapat hasil akan dilanjutkan ke agen yang lain untuk dianalisis hasilnya lalu dibuatkan perencanaan untuk serangan tahap selanjutnya, dan dieksekusi lagi dengan MCP Server. Hal ini berulang hingga seluruh agen menjalankan tugasnya.
g. Hasil keluaran dari setiap agen pengujian dianalisis

dan dijadikan laporan pengujian oleh LLM sesuai standar laporan OWASP WSTG.

h. User dapat mengunduh laporan pengujian.

4. Target Pengujian Keamanan

Untuk mengevaluasi sistem yang dikembangkan, pengujian dilakukan pada beberapa aplikasi benchmark yang telah diakui secara luas dalam komunitas keamanan siber. Target utama pengujian meliputi Damn Vulnerable Web Application (DVWA) dan OWASP Juice Shop. Kedua aplikasi ini dipilih dengan pertimbangan sebagai berikut:

a. Memiliki kerentanan yang terdokumentasi dengan baik sehingga dapat dijadikan *ground truth* dalam evaluasi
b. Mencakup berbagai kategori kerentanan yang relevan dengan OWASP Top 10 dan WSTG
c. Legal dan etis untuk digunakan sebagai target pengujian

5. Metode Pengujian dan Evaluasi

Evaluasi sistem dilakukan melalui tiga komponen utama yang saling melengkapi untuk memastikan untuk memastikan validitas dan reliabilitas hasil pengujian. Pendekatan ini mengikuti pola evaluasi sistem agen berbasis LLM yang telah divalidasi dalam penelitian sebelumnya.

a. Completion Rate

Completion Rate merupakan metrik utama yang mengukur kemampuan sistem dalam menyelesaikan test case berdasarkan standar OWASP WSTG 4.2. Metrik ini dipilih karena bersifat objektif, terukur, dan tidak memerlukan pembanding eksternal dengan arsitektur yang berbeda seperti penelitian sebelumnya.

Metrik yang digunakan:

- *Task Completion Rate* (TCR) yakni persentase test case yang berhasil diselesaikan secara penuh

$$TCR = \frac{\text{Jumlah Test Case Selesai}}{\text{Total Test Case WSTG}} \times 100\%$$

- *Subtask Completion Rate* (SCR) yakni persentase subtask dalam setiap case yang berhasil dieksekusi

$$SCR = \frac{\text{Jumlah Sub Task Selesai}}{\text{Total Sub Task}} \times 100\%$$

- *Category Completion Rate* (CCR) yakni persentase untuk setiap kategori pengujian (11 Poin WSTG)

$$CCR = \frac{\text{Jumlah Kategori Selesai}}{\text{Total Kategori}} \times 100\%$$

b. Pengujian Teknis (Testing)

Pengujian teknis dilakukan mengacu pada standar ISO/IEC/IEEE 29119:2021-2022 yang merupakan standar internasional terbaru untuk pengujian software.(Software and Systems Engineering-Software Testing-Part 1: General Concepts Foreword, 2022)

- *Unit Testing* yakni verifikasi setiap agen individial berfungsi sesuai spesifikasi. Mencakup pengujian fungsi komunikasi MCP dan eksekusi *tools* keamanan
- *Integration Testing* yakni verifikasi komunikasi dan koordinasi antar agen.
- *System Testing* yakni verifikasi workflow end-to-end dari inisiasi pengujian hingga pembuat laporan pada target
- *Performance Testing* yakni pengukuran resource yang digunakan. Selain itu, evaluasi akurasi sistem dilakukan dengan menghitung metrik Precision, Recall, dan F1-Score berdasarkan ground truth OWASP Juice Shop (Izzat et al., 2025)

c. User Acceptance Testing (UAT) dengan System Usability Scale (SUS)

User Acceptance Testing dilakukan untuk mengukur penerimaan dan persepsi pengguna terhadap sistem.(Aliyah Aliyah et al., 2024) UAT merupakan tahap akhir pengujian yang memvalidasi bahwa sistem memenuhi kebutuhan pengguna.

- Responden yakni 10-15 praktisi keamanan siber bersertifikasi dibidang penetration testing atau security assessment
- System Usability Scale (SUS) yakni kuesioner standar 10 item dengan skala Likert 5 poin. SUS telah divalidasi secara ekstensif untuk berbagai jenis sistem termasuk aplikasi digital dan sistem berbasis AI.(Fariyono & Sanjaya, 2023)
- Dengan Interpretasi Skor sebagai berikut:

Rentang Skor	Grade	Interpretasi
<51	F	Tidak Dapat Diterima
51 – 68	D	Marginal
68	C	Acceptable (rata-rata)
68 – 80.3	B	Good (diatas rata-rata)
>80.3	A	Excellent (top 10%)

(7) Hasil yang Diharapkan	Hasil yang diharapkan dari penelitian ini ialah terwujudnya prototipe sistem multiagen terspesialisasi berbasis LLM untuk pengujian keamanan aplikasi web. Arsitektur dirancang selaras dengan kategori pengujian pada OWASP Web Security Testing Guide versi 4.2 sehingga setiap agen memiliki tanggung jawab uji yang jelas sesuai bidangnya. Sistem ini mengintegrasikan lebih dari 15 alat pengujian *open-source* melalui protokol Model Context Protocol, dilengkapi dengan mekanisme anti-stuck untuk memastikan eksekusi berjalan dengan lancar serta dasbor web untuk memonitor secara langsung yang memungkinkan pengguna

	memantau proses pengujian berlangsung.
(8) Kata Kunci	*Agentic AI, Large Languange Model*, *Model Context Protocol*, *OWASP WSTG*, *Vulnerability Assessment*, *Web Security*

Bogor, 3 Desember 2025

Mengetahui,
Dosen Pendamping ICP

Penyusun

Dokumen Ini ditandatangani secara elektronik oleh:
Lektor

GIRINOTO, S.Si., M.Si.
Penata Tingkat I (III/d)

Ditandatangani Secara Elektronik Oleh:

MARTUA RAJA DOLI PANGARIBUAN
Tingkat IV Rekayasa Keamanan Siber A

NPM. 2221101809

Dokumen ini telah ditandatangani secara elektronik menggunakan sertifikat elektronik yang diterbitkan oleh Balai Sertifikasi Elektronik (BSrE), Badan Siber dan Sandi Negara